

APYEE PROTOCOL V2.1.3 REMEDIATION REVIEW

Smart Contract Audit — Round-3 Residual-Remediation Review Report

Apyee Protocol V2.1.3

Contract: VaultV2 + AaveV3 / CompoundV3 / Venus / Morpho / Fluid strategy adapters

Network: Ethereum, Base, Arbitrum, BNB Chain (identical bytecode per tier)

Deployment: Immutable, per-tier deployments

Report ID: APY-2026-06-002-B

Date: 2026-07-09

Base report: APY-2026-06-001 (V2.0 audit)

Verdict: PASS — all V2.1.2 residuals closed or addressed; 0 new findings; 0 regressions · Security

Score 91 / 100

Executive Dashboard

Overall Security Assessment

Field	Value
Project Name	Apyee Protocol V2.1.3
Component	Immutable ERC-4626 USDC yield aggregator
Vault	<code>VaultV2</code> (~1060 LOC)
Strategy adapters	<code>BaseStrategy</code> + AaveV3 / CompoundV3 / Venus / Morpho / Fluid
Asset	USDC (6 decimals; shares 12 decimals via <code>_decimalsOffset = 6</code>)
Solidity Version	<code>^0.8.28</code> (compiled / analyzed on <code>0.8.28</code> , EVM <code>cancun</code> , <code>viaIR: true</code>)
OpenZeppelin Version	<code>5.x</code> (ERC4626 / ERC20 / Ownable2Step / Pausable / ReentrancyGuard / SafeERC20 / Math)
Upgradeability	None (immutable, non-proxied)
License	BUSL-1.1
Tag reviewed	<code>v2.1.3</code> → commit <code>e737779</code> (merge of <code>feat/v2.1.3-soken-residuals</code> , <code>0d3a930</code>)
Base reports	<code>APY-2026-06-001</code> (V2 audit), <code>APY-2026-06-002</code> (V2.1.1 review), <code>APY-2026-06-002-A</code> (V2.1.2 review, 2026-07-06)
Residuals reviewed	5 open items from V2.1.2 (F-901, F-902, F-903, F-i02, F-i04) + 2 acknowledged (F-i01, F-i03)
Residuals closed (code)	F-901 (Info), F-902 (Low) — both fixed at the code level; F-902 re-verified by PoC
Residuals addressed (doc)	F-903 (Low), F-i02, F-i04, F-i01 — trust-split and second-order limits now documented in-code
Residuals still acknowledged	F-i03 — config setters not <code>onlyDeployChain</code> ; unchanged, remains a deploy-runbook item (no reachable sink today)
Changeset	2 files, +44 / -13 lines: <code>Vault.sol</code> (F-902 gate, F-901 <code>whenNotPaused</code>) + <code>BaseStrategy.sol</code> (F-i04/F-i02/F-903 doc)
Original 16 findings	All remain fully mitigated. Zero regressions.

Field	Value
New findings on V2.1.3 surface	0 Critical · 0 High · 0 Medium · 0 Low · 0 Informational
Methodology	Fix verification (source diff v2.1.2→v2.1.3) + PoC re-run of F-902 against the v2.1.3 tag + pause-matrix enumeration of every state-changing entrypoint + regression diff
Security Score	91 / 100 (from 88 / 100)
Overall Status	PASS — all remediable residuals closed; no new findings; no regressions

Test Card Summary

- **2 Low closed** — F-902 (code + PoC), F-903 (addressed within trust model via documentation)
- **1 Info closed (code)** — F-901 (`whenNotPaused` added)
- **3 Info addressed (doc)** — F-i01, F-i02, F-i04
- **1 Info acknowledged** — F-i03 (runbook)
- **0 new findings on the v2.1.3 surface**

1. Scope of this Review

1.1 What Changed Between V2.1.2 and V2.1.3

```
git diff --stat v2.1.2 v2.1.3 -- contracts/ :
```

```
contracts/Vault.sol | 38 ++++++-----
contracts/strategies/BaseStrategy.sol | 19 ++++++---
2 files changed, 44 insertions(+), 13 deletions(-)
```

Three substantive edits, each mapping to a V2.1.2 residual:

1. **Vault.sol** — **F-902 gate** (`_convertToAssets` / `_convertToShares`): the pending-fee term is now gated on the same-block accrue latch — `uint256 pf = (lastAccruedAt == block.timestamp) ? 0 : _pendingFeeShares();` — the exact one-line remediation recommended in APY-2026-06-002-A §5.2.
2. **Vault.sol** — **F-901 pause gate** (`investToStrategy`): now `onlyKeeper whenNotPaused nonReentrant` (was `onlyKeeper nonReentrant`), closing the last principal-in path during a Guardian pause. Recovery-direction paths (`divestFromStrategy` , `emergencyWithdraw`) intentionally remain pause-free.
3. **BaseStrategy.sol** — **documentation** (`setRewardFallbackPrice` and the swap floor): corrects the trust direction to **deflation** (F-i04), records the dust-truncation and USDC-at-\$1 second-order limits (F-i02), and cross-links the floor trust-split (F-903 / F-i01) to `TRUST_MODEL.md §9.7.2`.

No logic was added or removed outside these three edits. The changeset is a targeted residual-closure round; it does not touch the strategy adapters, accrual math, or the ERC-4626 core beyond the two gated overrides and the one pause modifier.

1.2 What This Review Covers

- Verification that each of the five open V2.1.2 residuals (F-901, F-902, F-903, F-i02, F-i04) is closed or correctly addressed at `v2.1.3`.
- A re-run of the F-902 adversarial PoC against the `v2.1.3` tag.
- A full pause-matrix enumeration to confirm the F-901 fix is complete and does not break exit/recovery.
- A regression pass confirming the two Low findings are closed without disturbing the original 16 findings or the accrual invariants.

2. Residual Status

ID	V2.1.2 severity	V2.1.3 disposition	Evidence
F-902	Low	CLOSED (code + PoC)	pf gate on both overrides; PoC delta +2.56% → 0
F-901	Info (Low under compromised-Keeper)	CLOSED (code)	whenNotPaused on investToStrategy ; pause matrix complete
F-903	Low	ADDRESSED (trust-model doc)	trust-split made explicit; floor code is trust-bounded by design, no code fix owed
F-i04	Info	CLOSED (code comment)	comment corrected: deflation, not inflation, disables the floor
F-i02	Info	ADDRESSED (doc)	dust-truncation + USDC-\\$1 limits now stated in NatSpec
F-i01	Info	ADDRESSED (doc)	floor framed as "Chainlink-strong for feed-backed, Owner-trust for feed-less"
F-i03	Info	ACKNOWLEDGED	config setters still not onlyDeployChain ; no reachable sink; deploy-runbook item

3. Verification Detail

3.1 F-902 (Low) — Fix #9 override bit-identical on the transactional path — CLOSED

Fix. Both view overrides now gate the pending-fee term on the accrue latch:

```
// _convertToAssets
uint256 pf = (lastAccruedAt == block.timestamp) ? 0 : _pendingFeeShares();
return shares.mulDiv(totalAssets() + 1, totalSupply() + pf + 10 ** _decimalsOffset(),
rounding);

// _convertToShares (mirror)
uint256 pf = (lastAccruedAt == block.timestamp) ? 0 : _pendingFeeShares();
return assets.mulDiv(totalSupply() + pf + 10 ** _decimalsOffset(), totalAssets() + 1,
rounding);
```

Correctness. On any transactional path (`deposit` / `mint` / `withdraw` / `redeem`), `_accrue()` runs first and sets `lastAccruedAt = block.timestamp`, so the gate forces `pf = 0` and the override collapses to base OZ math — bit-identical. In the residual gap the V2.1.2 review found (same-block: first accrue → USDC donation → later transactional op), `_accrue()` short-circuits without refreshing `lastSharePrice`, so the naïve `_pendingFeeShares()` was non-zero and diluted the mint. The gate now forces `pf = 0` in exactly that window — which is faithful, because a fresh `_accrue()` in the same block would also short-circuit and mint nothing. The gate is therefore a strict no-op wherever `_pendingFeeShares()` would already be 0, and forces 0 only in the donation-gap window; external view queries (no accrue that block) continue to receive the accrue-aware correction.

PoC re-run against the v2.1.3 tag (`Fix9_SameBlockAccrueLatch.t.sol`, single tx `accrue()` → `donate` → `deposit()`):

```
recovered offset unit (10**decimalsOffset): 1000000
pendingFeeShares seen mid-tx (raw public view, ungated): 25641025641025641
shares actually minted:      416666666666736111
shares base-OZ would mint:  416666666666736111
No behavioral delta: override stayed bit-identical on this path
--- exploitability ---
attacker put in (donation+deposit): 7000000000000
attacker got out on redeem:      4999999999999
attacker net P&L:                -2000000000001
```

Mint delta is now 0 (was +2.56% at V2.1.2). The control run (same-block double deposit, no donation) remains `pending = 0`, `delta = 0`. The public `pendingFeeShares()` accessor is intentionally left ungated (it reports the true economic pending fee for off-chain consumers); the "INVARIANT VIOLATED"

line the PoC prints keys off that public accessor and is now a false flag — the invariant that matters, transactional-path bit-identity, holds.

Verdict: CLOSED. The vendor's stated "no-op on the transactional path" invariant now actually holds, and the deposit-side dilution window is removed.

3.2 F-901 (Info) — `investToStrategy` pause-gated — CLOSED

Fix. `investToStrategy` is now `onlyKeeper whenNotPaused nonReentrant`.

Pause matrix (every external state-changing entrypoint at `v2.1.3`):

Entrypoint	Direction	<code>whenNotPaused</code> ?	Correct under pause
<code>deposit</code> / <code>mint</code>	principal-in	yes	halted ✓
<code>investToStrategy</code>	principal-in (idle → strategy)	yes (F-901)	halted ✓
<code>withdraw</code> / <code>redeem</code>	exit	no (by design)	open — users must exit ✓
<code>divestFromStrategy</code>	recovery	no (by design)	open — Keeper recovers ✓
<code>emergencyWithdraw</code>	recovery	no (by design)	open — Keeper recovers ✓
<code>accrue</code>	none (idempotent)	no	harmless ✓

Every principal-in path is now halted during a Guardian pause; every exit and recovery path stays open. The quarantine block (F-05) and per-strategy allocation cap on `investToStrategy` are retained. This is a complete, self-consistent pause model with no regression to fund exit or recovery.

Verdict: CLOSED.

3.3 F-903 (Low) — feed-less floor trust-split — ADDRESSED

The floor for feed-less reward tokens (FLUID, KINZA, SPK) remains derived from the Owner-set `rewardFallbackPriceE8`; this is a trust-model property, not a code defect, so no code change is owed. V2.1.3 makes the trust boundary explicit in NatSpec: the theft direction is **deflation** of the fallback price (collapses the floor, enabling a colluding-Keeper sandwich), which requires Owner + Keeper 2-of-2 collusion and sits inside `TRUST_MODEL.md §9.7.2`. Inflation only raises the floor (a liveness DoS on legitimate claims, not a theft vector). The `PRICE_STALENESS = 1 day` fail-closed revert is unchanged; the recommended mitigation is operational (a Keeper/Owner monitoring runbook item for feed-less price freshness ahead of URD-campaign deadlines), which is a process control, not a contract change.

Verdict: ADDRESSED within the documented trust model.

3.4 Informational — F-i04 CLOSED, F-i01 / F-i02 ADDRESSED, F-i03 ACKNOWLEDGED

- **F-i04 — CLOSED.** The `setRewardFallbackPrice` comment no longer states the trust direction backwards; it now reads that a malicious Owner who *deflates* the value collapses the floor (the real theft direction), with inflation only a liveness DoS.
- **F-i01 — ADDRESSED.** The floor is now framed as "Chainlink-strong for feed-backed tokens, Owner-trust for feed-less tokens," so the F-903 residual is no longer obscured behind a uniform "on-chain floor" phrasing.
- **F-i02 — ADDRESSED.** NatSpec now records the two second-order limits: the floor truncates to 0 for dust `amountIn` when `rewardDec > underlyingDec` (immaterial — dust output is dust), and the output side is priced against USDC at \$1 (a second-order skew only during a USDC depeg).
- **F-i03 — ACKNOWLEDGED.** Owner config setters remain non-`onlyDeployChain`. Their only sink is the chain-gated `claimAndCompound`, so there is no fork-replay surface today; this stays a deploy-runbook note, unchanged from V2.1.2.

4. Regression — Original 16 Findings & Accrual Invariants

`git diff v2.1.2 v2.1.3 -- contracts/` confirms the changeset is additive/gated: no existing logic line in the accrual engine (`_accrue` , `_pendingFeeShares` , `_feeSharesFor` , `_calcSharePrice`), the strategy adapters, or the ERC-4626 core was deleted or altered. The two overrides differ only by the introduction of the `pf` latch variable; `investToStrategy` differs only by one modifier.

- **F-01...F-17 (round-1):** unchanged, all still-closed. The F-902 gate is a strict extension of F-01 (accrue-before-preview) — it makes the view override reproduce exactly what the transactional `_accrue()` would (not) mint this block.
- **Accrual invariants:** the F-902 control test (same-block double deposit, no donation) returns `delta = 0` , confirming normal multi-op-per-block flows stay bit-identical. The gate forces `pf = 0` only where a fresh accrue would also produce 0, so it introduces no new share-price path.
- **Exit / recovery:** the F-901 pause matrix confirms `withdraw` , `redeem` , `divestFromStrategy` , `emergencyWithdraw` remain pause-free — no regression to fund exit under a Guardian pause.

"Original 16 remain fully mitigated, nothing removed or relaxed" — CONFIRMED.

5. Deployment Advisory (non-finding)

The reviewed artifact is the annotated **v2.1.3 tag** (commit `e737779`), which contains all three fixes above. During review, the repository's working-tree **HEAD** (`7ee79fb`, a fuzz-harness commit) was observed to **diverge** from the **v2.1.3 tag** — it strips ~1,470 lines across contracts and, notably, **reverts the F-901 fix** (`investToStrategy` lacks `whenNotPaused` at that HEAD). This is not a defect in **v2.1.3**, but a release-hygiene item: **confirm that the deployment pipeline builds from the **v2.1.3 tag** (or a descendant that preserves it), not from the divergent **HEAD****. If the deployed bytecode is built from `7ee79fb`, the F-901 pause gate will be absent from production despite being fixed in the tag.

6. Verdict

PASS — all remediable residuals closed; no new findings; no regressions.

- **F-902 (Low)** — closed at the code level and re-verified by PoC against the `v2.1.3` tag: transactional-path mint delta `+2.56% → 0` ; control unchanged; the vendor's stated no-op invariant now holds.
- **F-901 (Info / Low-under-compromised-Keeper)** — closed; the pause model is now complete across all principal-in paths while preserving exit and recovery.
- **F-903 (Low)** — addressed within the documented Owner-trust model; the trust split is now explicit and the residual is operational, not a contract defect.
- **F-i01 / F-i02 / F-i04** — documentation corrected/clarified. **F-i03** — acknowledged, runbook item, no reachable sink.
- **Zero regressions** on the original 16 findings and the accrual invariants; the changeset is a targeted, additive residual-closure round.
- **New surface on v2.1.3: 0 Critical / 0 High / 0 Medium / 0 Low / 0 Info.**

Security score: 91 / 100 (from 88 / 100). The remaining gap to 100 is inherent trust-model surface (feed-less floor, Owner/Keeper privileges) that is architectural, documented, and outside the scope of a code fix — not an open defect.

Reviewed at tag `v2.1.3` (`e737779`). PoC artifacts: `poc_v2.1.2/Fix9_SameBlockAccrueLatch.t.sol` , re-run against `v2.1.3` .